



ATHENS UNIVERSITY
OF ECONOMICS
AND BUSINESS

ΤΜΗΜΑ ΠΛΗΡΟΦΟΡΙΚΗΣ | ΕΑΡΙΝΟ ΕΞΑΜΗΝΟ 2025-2026
ΚΑΘΗΓΗΤΗΣ: ΔΗΜΗΤΡΗΣ ΓΚΡΙΤΖΑΛΗΣ



SOLARWINDS®

INVISIBLE THREAT

THE EVOLUTION OF CYBER THREATS: SOLARWINDS AS A
TURNING POINT IN SOFTWARE SUPPLY CHAIN INTEGRITY
AND GLOBAL DIGITAL DEFENSE.

ΠΕΡΙΛΗΨΗ

Σκοπός της παρούσας εργασίας είναι η εκτενής ανάλυση της περίφημης επίθεσης εφοδιαστικής αλυσίδας (supply-chain attack) που έπληξε τη SolarWinds και αποτελεί ορόσημο στην ιστορία της κυβερνοασφάλειας. Αναλύεται ο τρόπος με τον οποίο κρατικά υποστηριζόμενοι επιτιθέμενοι κατάφεραν να παραβιάσουν την διαδικασία παραγωγής της εταιρείας (build process) του λογισμικού Orion, με βάση το πλαίσιο MITRE ATT&CK. Τέλος, αξιολογούνται οι λόγοι αποτυχίας των παραδοσιακών συστημάτων ανίχνευσης και προτείνονται στρατηγικές θωράκισης και ασφάλειας της εταιρείας και των συστημάτων της.

"From a software engineering perspective, I think it's fair to say that this is the largest and most sophisticated attack the world has ever seen."

—Brad Smith, Πρόεδρος της Microsoft.



ΠΕΡΙΕΧΟΜΕΝΑ

01

ΕΙΣΑΓΩΓΗ

02

ΜΕΡΟΣ Α: ΤΟ ΠΕΡΙΣΤΑΤΙΚΟ SOLARWINDS: ΧΡΟΝΟΛΟΓΙΟ, ΜΗΧΑΝΙΣΜΟΣ ΚΑΙ ΕΥΡΟΣ ΕΠΙΠΤΩΣΕΩΝ

- 2.1 Η ΕΤΑΙΡΕΙΑ SOLARWINDS ΚΑΙ ΤΟ ΛΟΓΙΣΜΙΚΟ ORION
2.2 Η ΦΥΣΗ ΤΗΣ ΕΠΙΘΕΣΗΣ ΕΦΟΔΙΑΣΤΙΚΗΣ ΑΛΥΣΪΔΑΣ (SUPPLY CHAIN ATTACK)
2.3 Η ΑΝΑΚΑΛΥΨΗ ΤΟΥ ΠΕΡΙΣΤΑΤΙΚΟΥ
2.4 ΕΚΤΑΣΗ, ΘΥΜΑΤΑ ΚΑΙ ΕΠΙΠΤΩΣΕΙΣ

03

ΜΕΡΟΣ Β: ΕΜΒΑΘΥΝΣΗ ΣΤΟΝ ΚΥΚΛΟ ΖΩΗΣ ΤΗΣ ΕΠΙΘΕΣΗΣ: ΤΕΧΝΙΚΗ ΑΝΑΛΥΣΗ ΚΑΙ ΧΑΡΤΟΓΡΑΦΗΣΗ ΣΤΟ ΠΛΑΪΣΙΟ MITRE ATT&CK.

- 3.1 ΠΙΘΑΝΑ ΣΕΝΑΡΙΑ ΑΡΧΙΚΗΣ ΕΙΣΟΔΟΥ (INITIAL VECTORS)
3.2 ΣΤΑΔΙΟ 1: ΑΡΧΙΚΗ ΠΡΟΣΒΑΣΗ (INITIAL ACCESS)
3.3 ΣΤΑΔΙΟ 2: ΕΚΤΕΛΕΣΗ & ΕΓΚΑΘΪΔΡΥΣΗ (EXECUTION & PERSISTENCE)
3.4 ΣΤΑΔΙΟ 3: ΑΠΟΦΥΓΗ ΑΝΪΧΝΕΥΣΗΣ (DEFENSE EVASION)
3.5 ΣΤΑΔΙΟ 4: ΕΝΤΟΛΕΣ ΚΑΙ ΈΛΕΓΧΟΣ (COMMAND & CONTROL)
3.6 ΣΤΑΔΙΟ 5: ΚΛΙΜΑΚΩΣΗ ΠΡΟΝΟΜΪΩΝ & ΠΛΕΥΡΙΚΗ ΜΕΤΑΚΪΝΗΣΗ
(PRIVILEGE ESCALATION & LATERAL MOVEMENT)
3.7 ΣΤΑΔΙΟ 6: ΣΥΛΛΟΓΗ & ΕΞΑΓΩΓΗ (COLLECTION & EXFILTRATION)
3.8 ΧΡΟΝΙΚΟ (TIMELINE) ΤΗΣ ΕΠΙΘΕΣΗΣ

04

ΜΕΡΟΣ Γ: ΓΙΑΤΪ ΑΠΪΕΤΥΧΕ Ο ΕΝΤΟΠΙΣΜΟΣ: ΑΝΑΛΥΣΗ ΚΕΝΩΝ ΑΣΦΑΛΕΪΑΣ ΚΑΙ ΣΪΥΓΧΡΟΝΕΣ ΣΤΡΑΤΗΓΙΚΈΣ ΑΜΥΝΑΣ.

- 4.1 ΑΙΤΪΕΣ ΚΑΘΪΣΤΕΡΗΜΈΝΟΥ ΕΝΤΟΠΙΣΜΟΥ (ΓΙΑΤΪ Η ΕΠΪΘΕΣΗ ΠΑΡΈΜΕΙΝΕ
"ΑΪΡΑΤΗ")
4.2 Η ΕΣΦΑΛΜΈΝΗ ΑΠΪΔΟΣΗ ΑΙΤΪΟΤΗΤΑΣ: Ο ΜΪΥΘΟΣ ΤΟΥ "SOLARWINDS123"
4.3 ΣΤΡΑΤΗΓΙΚΆ ΜΈΤΡΑ ΘΩΡΑΚΪΣΗΣ ΚΑΙ ΑΠΟΤΡΟΠΪΗΣ

05

ΣΥΜΠΕΡΑΣΜΑ

06

ΒΪΒΛΪΟΓΡΑΦΪΑ



01

ΕΙΣΑΓΩΓΗ

Στα τέλη του 2020, η κυβερνοεπίθεση στη SolarWinds καταγράφηκε ως μία από τις πιο κρίσιμες επιθέσεις αλυσίδας εφοδιασμού (supply chain attacks) στην ιστορία. Μετατρέποντας το λογισμικό Orion σε "Δούρειο Ίππο", οι επιτιθέμενοι απέκτησαν αθόρυβη, μακροχρόνια πρόσβαση σε αμερικανικές κρατικές υπηρεσίες και μεγάλους οργανισμούς, αποκαλύπτοντας τις συστημικές αδυναμίες της παγκόσμιας κυβερνοασφάλειας.

ΥΠΟΕΝΌΤΗΤΑ 2.1: Η ΕΤΑΙΡΕΪΑ SOLARWINDS ΚΑΙ ΤΟ ΛΟΓΙΣΜΙΚΌ ORION

Η αμερικανική εταιρεία τεχνολογίας SolarWinds, ιδρυθείσα το 1999, παρέχει εργαλεία παρακολούθησης και διαχείρισης IT. Το πελατολόγιο της περιλαμβάνει κορυφαίες εταιρείες του Fortune 500 και πολυάριθμους κυβερνητικούς φορείς των ΗΠΑ (SolarWinds Corporation, 2020). Προσφέρει μια ποικιλία προϊόντων που βοηθούν τους οργανισμούς να διαχειρίζονται δίκτυα, συστήματα, υποδομές IT, εφαρμογές και υπηρεσίες που βασίζονται στο cloud. Το κεντρικό προϊόν της εταιρείας, η πλατφόρμα Orion, απαιτεί εκ σχεδιασμού καθολικά προνόμια για να παρακολουθεί και να διαχειρίζεται αποτελεσματικά το δίκτυο. Αυτή η προνομιακή πρόσβαση στον πυρήνα των συστημάτων, κατέστησε το λογισμικό Orion ως τον ιδανικό στόχο επιθέσεων (Kruti, Butt and Sulaiman, 2023).

ΥΠΟΕΝΌΤΗΤΑ 2.2 Η ΦΎΣΗ ΚΑΙ Ο ΣΚΟΠΌΣ ΤΗΣ ΕΠΊΘΕΣΗΣ (SUPPLY - CHAIN ATTACK)

Το περιστατικό αποτελεί το πλέον χαρακτηριστικό παράδειγμα επιτυχημένης παραβίασης μιας εφοδιαστικής αλυσίδας λογισμικού (Fortinet, n.d.). Μία κρατικά υποστηριζόμενη ομάδα (APT29), επέλεξε να παραβιάσει απευθείας τη διαδικασία παραγωγής (build process) του έμπιστου προμηθευτή (CISA, 2020). Αυτή η κίνηση ερχόταν σε αντίθεση με τις μέχρι ως τότε γνωστές επιθέσεις, οι οποίες στόχευαν εξ αρχής τα τελικά θύματα. Οι επιτιθέμενοι ενσωμάτωσαν τον κακόβουλο κώδικα με την ονομασία SUNBURST σε μία νόμιμη, ψηφιακά υπογεγραμμένη ενημέρωση του Orion, γεγονός που οδήγησε στην ενημέρωση να λειτουργήσει πρακτικά ως “Δούρειος Ίππος”, αφού εγκαθιστόταν από τα ίδια τα θύματα (CISA, 2021b).

ΥΠΟΕΝΌΤΗΤΑ 2.3 Η ΑΝΑΚΆΛΥΨΗ ΤΟΥ ΠΕΡΙΣΤΑΤΙΚΟΎ

Μολονότι η διανομή των κακόβουλων ενημερώσεων ξεκίνησε γύρω στην άνοιξη του 2020, η ανακάλυψη της επίθεσης έγινε παγκοσμίως γνωστή τον Δεκέμβριο του ίδιου έτους από την εταιρεία κυβερνοασφάλειας FireEye (Mandiant, 2020). Το κρίσιμο σημείο, που αποκάλυψε την απειλή, υπήρξε η ειδοποίηση του συστήματος όταν οι επιτιθέμενοι προσπάθησαν να καταχωρήσουν μία μη εξουσιοδοτημένη συσκευή στο σύστημα Ταυτοποίησης Πολλαπλών Παραγόντων (MFA) ενός υπαλλήλου της εταιρείας. Ύστερα από σχολαστική διερεύνηση, αποκαλύφθηκε, αρχικά, η υποκλοπή εργαλείων ελέγχου (Red Team Tools) της FireEye ενώ αργότερα, αναλύοντας την επίθεση γνωστοποιήθηκε η αρχική παραβίαση, που προερχόταν από το λογισμικό της Orion.

ΥΠΟΕΝΏΤΗΤΑ 2.4 ΈΚΤΑΣΗ, ΘΎΜΑΤΑ ΚΑΙ ΕΠΙΠΤΏΣΕΙΣ

Υπολογίζεται ότι περίπου 18.000 πελάτες κατέβασαν την μολυσμένη έκδοση του Orion (SolarWinds Corporation, 2020). Ωστόσο, εξυπηρετώντας σκοπούς αυστηρά στοχευμένης κυβερνοκατασκοπείας, το τελικό στάδιο ενεργοποιήθηκε σε λιγότερους από 100 επιλεγμένους στόχους υψηλής αξίας (GAO, 2022). Ανάμεσα στα θύματα συμπεριλαμβάνονται το Πεντάγωνο, η NASA, η NSA και κορυφαία Υπουργεία των ΗΠΑ. Οι δράστες χρησιμοποίησαν ενδιάμεσους διακομιστές (Jump Servers) για να συλλέξουν δεδομένα αθόρυβα. Υπέκλεψαν τον πηγαίο κώδικα του Orion, emails υπαλλήλων-στόχων, διευθύνσεις IP, MAC και κρυπτογραφημένους κωδικούς. Ο οικονομικός και νομικός αντίκτυπος για τη SolarWinds ήταν καταστροφικό. Η χρηματιστηριακή της αξία υπέστη ραγδαία πτώση κατά 25%, ενώ παράλληλα βρέθηκε αντιμέτωπη με αγωγές και αυστηρές έρευνες από την Επιτροπή Κεφαλαιαγοράς (SEC). Είναι καίριο να υπογραμμίσουμε πως τον Οκτώβριο του 2023, η SEC άσκησε πρωτοφανείς νομικές διώξεις εις βάρος της εταιρείας και του Επικεφαλής Ασφαλείας (CISO) για παραπλάνηση των επενδυτών σχετικά με τις εσωτερικές πρακτικές ελέγχου (SEC, 2023). Σε μακροπρόθεσμο επίπεδο, το περιστατικό ανέδειξε τον τεράστιο συστημικό κίνδυνο (Systemic Risk) που προκύπτει από την εξέταση σε μεμονωμένους προμηθευτές, καθιστώντας επιτακτική τη μετάβαση σε αρχιτεκτονικές Zero Trust (NIST, 2020).

Η ανατομία της επίθεσης ενάντια στη SolarWinds αναλύεται τεχνικά με βάση το πλαίσιο MITRE ATT&CK. Για μία πιο σφαιρική κατανόηση, η δράση των επιτιθέμενων χωρίζεται στα ακόλουθα στάδια, αναδεικνύοντας την αλυσίδα των εργαλείων (SUNSPOT, SUNBURST, Teardrop/Raindrop) που χρησιμοποιήθηκαν.

ΥΠΟΕΝΌΤΗΤΑ 3.1 ΠΙΘΑΝΑ ΣΕΝΆΡΙΑ ΑΡΧΙΚΉΣ ΕΙΣΌΔΟΥ (INITIAL VECTORS)

Ο ακριβής τρόπος με τον οποίο οι επιτιθέμενοι απέκτησαν την αρχική πρόσβαση στα συστήματα της SolarWinds δεν έχει διασταυρωθεί, ωστόσο είναι σαφές ότι δεν πρόκειται για απλή αμέλεια. Οι επικρατούμενες θεωρίες για το αρχικό διάνυσμα επίθεσης είναι οι εξής (CISA, 2020):

1. Επίθεση ωμής βίας (Brute-force attack), όπως μια επίθεση password spray (η πιο πιθανή αιτία).
2. Εκμετάλλευση ευπάθειας μηδενικής ημέρας (Zero-day vulnerability) σε εφαρμογή ή συσκευή τρίτου κατασκευαστή.
3. Κοινωνική μηχανική (Social engineering), πιθανότατα μέσω στοχευμένου ηλεκτρονικού ψαρέματος (spear-phishing)

ΥΠΟΕΝΌΤΗΤΑ 3.2 ΣΤΑΔΙΟ 1: ΑΡΧΙΚΉ ΠΡΌΣΒΑΣΗ (INITIAL ACCESS)

Η επίθεση ξεκίνησε με την αθόρυβη διείσδυση στο εταιρικό δίκτυο της SolarWinds. Παρόλο που το αρχικό διάνυσμα εισόδου παραμένει επισήμως αδιευκρίνιστο, η ανάλυση τείνει στην παραβίαση των εσωτερικών λογαριασμών της εταιρείας. Οι εισβολείς απέσπασαν διαπιστευτήρια, πιθανότατα εφαρμόζοντας επιθέσεις “ψεκασμού κωδικού” (password spraying), αποφεύγοντας έτσι τον αποκλεισμό λογαριασμών που προκαλούν οι επιθέσεις ωμής βίας.

ΤΕΧΝΙΚΗ & ΑΝΤΙΣΤΟΙΧΙΣΗ MITRE ATT&CK:

1. Windows Service (T1543.003)
2. Code Signing (T1553.002)

Τρόπος Επηρεασμού: Η κατοχή έγκυρων διαπιστευτηρίων επέτρεψε στους εισβολείς να μιμηθούν τη συμπεριφορά νόμιμων υπαλλήλων. Αυτό είχε ως αποτέλεσμα, να παρακαμφθούν πλήρως οι έλεγχοι ασφαλείας, επηρεάζοντας έτσι, το σύστημα με την ανεμπόδιστη πλευρική τους μετακίνηση (lateral movement) από το περιβάλλον του Office 365 έως του κρίσιμους διακομιστές παραγωγής (build servers). Από εκεί, μόλυναν την εφοδιαστική αλυσίδα (Supply Chain) εισάγοντας το backdoor SUNBURST στην επίσημη ενημέρωση του Orion. Το μολυσμένο update λειτούργησε ως “Δούρειος Ίππος”, κληρονομώντας τα υψηλά δικαιώματα (pervasive privileges) του Orion.

ΥΠΟΕΝΌΤΗΤΑ 3.3 ΣΤΑΔΙΟ 2: ΕΚΤΈΛΕΣΗ & ΕΓΚΑΘΉΔΡΥΣΗ (EXECUTION & PERSISTENCE)

Στο περιβάλλον παραγωγής, οι εισβολείς έπρεπε να μολύνουν το λογισμικό χωρίς να αλλοιώσουν τον πηγαίο κώδικα των αρχείων της εταιρείας. Για τον σκοπό αυτό, ανέπτυξαν το SUNSPOT, ένα εξειδικευμένο κακόβουλο λογισμικό που εκτελούνταν απευθείας στη μνήμη RAM (fileless malware) με προνόμια συστήματος (SYSTEM privileges). Το SUNSPOT παρακολουθούσε τη διεργασία μεταγλώττισης MsBuild.exe. Τη στιγμή που αυτή ξεκινούσε, το νόμιμο αρχείο InventoryManager.cs αντικαθιστούνταν προσωρινά με μία μολυσμένη έκδοχή που περιείχε το backdoor SUNBURST. Αμέσως μετά την επιτυχή μεταγλώττιση και εφόσον είχε ήδη επιβεβαιώσει την απουσία σφαλμάτων μέσω ελέγχων κατακερματισμού (checksums), επανέφερε τον αρχικό κώδικα (CrowdStrike, 2021).

ΤΕΧΝΙΚΗ & ΑΝΤΙΣΤΟΙΧΙΣΗ MITRE ATT&CK:

1. Windows Service (T1543.003)
2. Code Signing (T1553.002)

Τρόπος Επηρεασμού: Το σύστημα παραγωγής επηρεάστηκε με τέτοιο τρόπο ώστε να παράγει μολυσμένα εκτελέσιμα αρχεία (DLLs) τα οποία έφεραν την έγκυρη και επίσημη ψηφιακή υπογραφή (Code Signing) της SolarWinds. Γεγονός που επέτρεψε την παράκαμψη των ελέγχων ακεραιότητας. Επιπροσθέτως, μέσω της προσθήκης διαπιστευτηρίων σε Azure/M365 application service principals και νέων federation trusts, οι δράστες εξασφάλισαν μόνιμη, αθόρυβη εγκαθίδρυση τοπικά αλλά και στο cloud. Επηρεάσε το σύστημα αποκτώντας προγραμματιστική πρόσβαση στους πόρους του cloud χωρίς να παράγονται ύποπτα ίχνη (telemetry).

ΥΠΟΕΝΌΤΗΤΑ 3.4 ΣΤΑΔΙΟ 3: ΑΠΟΦΥΓΉ ΑΝΉΧΝΕΥΣΗΣ (DEFENSE EVASION)

Μετά την επιτυχή εγκατάσταση στους τελικούς χρήστες, το SUNBURST δεν ξεκινούσε αμέσως την κακόβουλη δραστηριότητά του. Αντ' αυτού, παρέμενε σε κατάσταση «λήθαργου» (dormancy) για ένα διάστημα 12 έως 14 ημερών (Mandiant, 2020). Η εσκεμμένη αυτή καθυστέρηση, έθετε πια τις αναλύσεις πολλών συστημάτων ασφαλείας, που εξετάζουν και εκτελούν νέα αρχεία σε εικονικά περιβάλλοντα (sandboxes) για σύντομο χρονικό διάστημα, άχρηστες.

ΤΕΧΝΙΚΗ & ΑΝΤΙΣΤΟΙΧΙΣΗ MITRE ATT&CK:

1. Obfuscated Files or Information (T1027)
2. Steganography (T1027.003)
3. Indicator Removal on Host: File Deletion (T1070.004)
4. Software Discovery: Security Software (T1518.001)

Τρόπος Επηρεασμού: Το κακόβουλο λογισμικό ακύρωσε τις περισσότερες κοινές αμυντικές ικανότητες των δικτύων. Παράλληλα, διενεργούσε ελέγχους στο περιβάλλον του και αν εντόπιζε συγκεκριμένες διευθύνσεις IP που ανήκαν σε sandboxes ή εργαλεία ανάλυσης όπως το WireShark σταματούσε αυτόματα την εκτέλεσή του. Κατάφερε έτσι να εισάγει απρόβλεπτες χρονικές καθυστερήσεις, με αποτέλεσμα να δυσκολέψει την παραδοσιακή ανάλυση δικτύου και να παραμείνει αόρατο τελικά για μήνες (Symantec, 2021).

ΥΠΟΕΝΌΤΗΤΑ 3.5 ΣΤΑΔΙΟ 4: ΕΝΤΟΛΈΣ ΚΑΙ ΈΛΕΓΧΟΣ (COMMAND & CONTROL)

Μετά το πέρας της περιόδου ληθάργου, το SUNBURST ερχόταν σε επικοινωνία με τους διακομιστές εντολών (C2) των επιτιθέμενων. Η κίνηση αυτή ενσωματώθηκε μέσα στο νόμιμο πρωτόκολλο καταλόγου του Orion (Orion Improvement Program), προκειμένου να μείνει απαρατήρητη η επικοινωνία από τα εταιρικά firewalls.

ΤΕΧΝΙΚΗ & ΑΝΤΙΣΤΟΙΧΙΣΗ MITRE ATT&CK:

1. Application Layer Protocol DNS (T1071.004)
2. Web Protocols (T1071.001)
3. Domain Generation Algorithms (DGA) (T1568.002)

Τρόπος Επηρεασμού: Οι επιτιθέμενοι απέκτησαν τη δυνατότητα να αποστέλλουν νέες εντολές καθώς και να ελέγχουν τα συστήματα διαδραστικά, μέσω της χρήσης αλγορίθμων DGA για τη δημιουργία subdomains του ansvmcloud[.]com. Ακόμη, δρομολογώντας την κίνηση μέσω εικονικών ιδιωτικών διακομιστών (VPS) (Symantec, 2021) που βρίσκονταν στην ίδια γεωγραφική χώρα με το εκάστοτε θύμα, ο αντίπαλος επηρέασε τα συστήματα παρακολούθησης συγκαλύπτοντας την εχθρική κίνηση μέσα στην νόμιμη κίνηση των χρηστών, αποτρέποντας έτσι τον εντοπισμό.

ΥΠΟΕΝΌΤΗΤΑ 3.6 ΣΤΑΔΙΟ 5: ΚΛΙΜΆΚΩΣΗ ΠΡΟΝΟΜΪΩΝ & ΠΛΕΥΡΙΚΉ ΜΕΤΑΚΊΝΗΣΗ (PRIVILEGE ESCALATION & LATERAL MOVEMENT)

Από τη στιγμή που το δίκτυο τέθηκε υπό έλεγχο μέσω του SUNBURST, οι επιτιθέμενοι προχώρησαν στην ανάπτυξη δευτερογενών εργαλείων, όπως τα “Teardrop” και “Raindrop” για να εγκαθιδρύσουν συνεδρίες Cobalt Strike, ένα πανίσχυρο εργαλείο για ομάδες ασφαλείας που τεστάρουν δίκτυα. Το Teardrop αξιοποιήθηκε στα αρχικά στάδια για να φορτώσει το Cobalt Strike, ενώ το Raindrop για την πλευρική κίνηση των επιτιθέμενων, με σκοπό να μην χρησιμοποιήσουν ξανά το SUNBURST και να κινήσουν έτσι υποψίες. Ο τελικός τους στόχος ήταν ο πυρήνας της ταυτοποίησης των θυμάτων: οι διακομιστές Active Directory Federation Services (ADFs) (Microsoft, 2021).

ΤΕΧΝΙΚΗ & ΑΝΤΙΣΤΟΙΧΙΣΗ MITRE ATT&CK:

1. SAML Token Abuse (μέρος του T1550.001 - Use Alternate Authentication Material)
2. Ingress Tool Transfer (T1105)

Τρόπος Επηρεασμού: Αποκτώντας πρόσβαση στον διακομιστή ADFs, οι επιτιθέμενοι υπέκλεψαν το ιδιωτικό κλειδί (private key) και το πιστοποιητικό υπογραφής (signing certificate) του οργανισμού. Επηρεάζοντας με αυτόν τον τρόπο τη ρίζα της εμπιστοσύνης, εκτέλεσαν την τεχνική “Golden SAML”. Δημιουργούσαν πλαστά -αλλά τεχνικά καθ’ όλα έγκυρα- SAML tokens, υποδυόμενοι οποιονδήποτε χρήστη επιθυμούσαν, χωρίς να χρειάζονται τους κωδικούς του. Αυτό τους έδωσε τη δυνατότητα να μετακινούνται ελεύθερα (lateral movement), παρακάμπτοντας πλήρως τον Έλεγχο Ταυτότητας Πολλαπλών Παραγόντων (MFA) (Vijayan, 2020). Στα logs, η δραστηριότητά τους καταγραφόταν ως απολύτως φυσιολογική, καθιστώντας έτσι σχεδόν αδύνατη την ανίχνευση της με συμβατικούς τρόπους. Συνεπώς, ακόμη κι αν έχαναν την πρόσβαση μέσω Orion, θα μπορούσαν να μπαίνουν στο cloud (Microsoft 365) των θυμάτων τους.

ΥΠΟΕΝΌΤΗΤΑ 3.7 ΣΤΑΔΙΟ 6: ΣΥΛΛΟΓΉ ΚΑΙ ΕΞΑΓΩΓΉ (COLLECTION & EXFILTRATION)

Το τελικό στάδιο αφορούσε την επίτευξη του αντικειμενικού σκοπού: την κυβερνοκατασκοπεία. Οι επιτιθέμενοι, έχοντας πλέον την απόλυτη πρόσβαση στα περιβάλλοντα Microsoft 365, στοχοποίησαν συγκεκριμένα στελέχη και προσωπικό πληροφορικής, υποκλέπτοντας εταιρικά emails και έγγραφα στρατηγικής σημασίας.

ΤΕΧΝΙΚΗ & ΑΝΤΙΣΤΟΙΧΙΣΗ MITRE ATT&CK:**1. Data Encoding: Standard Encoding (T1132.001)**

Τρόπος Επηηρεασμού: Ειδικότερα, προκειμένου να εξάγουν τα δεδομένα χωρίς να ενεργοποιήσουν συναγερμούς, η ροή πληροφοριών - πριν αποσπαστεί - υπέστη κωδικοποίηση (Standard Encoding), παρακάμπτοντας έτσι τα συστήματα Data Loss Prevention (DLP) που σαρώνουν για λέξεις-κλειδιά (CISA, 2021a). Ο τρόπος επηρεασμού του οργανισμού ήταν απόλυτος, καθώς η εξαγωγή δεδομένων (data exfiltration) διενεργήθηκε μέσω "νόμιμων" καναλιών (authorized APIs) από πλαστογραφημένους λογαριασμούς (SAML tokens), με αποτέλεσμα να μην αναγνωριστεί η παραβίαση απορρήτου (data breach) τη στιγμή που συνέβαινε.

ΥΠΟΕΝΌΤΗΤΑ 3.8 ΤΟ ΧΡΟΝΙΚΌ (TIMELINE) ΤΗΣ ΕΠΪΘΕΣΗΣ**ΗΜΕΡΟΜΗΝΙΑ****ΓΕΓΟΝΟΣ****ΙΑΝΟΥΑΡΙΟΣ 2019**

Ενδείξεις αρχικής μη εξουσιοδοτημένης πρόσβασης στα εσωτερικά συστήματα της SolarWinds.

ΣΕΠΤΈΜΒΡΙΟΣ 2019

(4/9) Οι επιτιθέμενοι αποκτούν πλήρης πρόσβαση στο περιβάλλον δημιουργίας λογισμικού (build environment).

(12/9) Πρώτη δοκιμαστική λειτουργία (test run) όπου εισάγεται ακίνδυνος κώδικας προκειμένου να ελεγχθεί εάν η παρέμβαση στη μεταγλώττιση θα προκαλέσει σφάλματα στην αρχιτεκτονική του Orion.

ΝΟΈΜΒΡΙΟΣ 2019

Ολοκλήρωση της δοκιμαστικής εισαγωγής κώδικα (test run ends).

20 ΦΕΒΡΟΥΑΡΙΟΥ 2020

Μεταγλώττιση (compile) και πραγματική εισαγωγή του κακόβουλου λογισμικού SUNBURST στον πηγαίο κώδικα του Orion, από το SUNSPOT.

ΗΜΕΡΟΜΗΝΙΑ

ΓΕΓΟΝΟΣ

Μ'ΑΡΤΙΟΣ - ΙΟ'ΥΝΙΟΣ 2020

Η SolarWinds διανέμει τις μολυσμένες (trojanised), ψηφιακά υπογεγραμμένες ενημερώσεις σε περίπου 18.000 πελάτες. Το SUNBURST ενεργοποιείται και ξεκινάει η κυβερνοκατασκοπεία (έπειτα από 2 εβδομάδες αδράνειας του malware).

4 ΙΟΥΝ'ΙΟΥ 2020

Οι επιτιθέμενοι αφαιρούν προληπτικά το SUNSPOT από το περιβάλλον της SolarWinds για να εξαφανίσουν τα ίχνη τους.

ΝΟ'ΕΜΒΡΙΟΣ 2020

Η FireEye εντοπίζει εσωτερική ύποπτη δραστηριότητα στα συστήματα MFA της.

ΔΕΚ'ΕΜΒΡΙΟΣ 2020

(8/12) Η FireEye ανακοινώνει την παραβίαση των Red Team εργαλείων της.
(12/12) Η FireEye ταυτοποιεί τον φορέα μόλυνσης και ενημερώνει ιδιωτικά τη SolarWinds για την παραβίαση του Orion.
(13-14/12) Δημόσια αποκάλυψη, έκδοση τεχνικών αναφορών και ενημέρωση της Επιτροπής Κεφαλαιαγοράς (SEC). (15-17/12) Microsoft, CISA και US-CERT εκδίδουν προειδοποιήσεις και παρεμποδίζουν την κακόβουλη δικτυακή κίνηση.

ΙΑΝΟΥΑΡΙΟΣ - ΑΠΡ'ΙΛΙΟΣ 2021

Δημοσίευση αναλυτικών στοιχείων και ερευνών. Τον Απρίλιο γίνεται η επίσημη απόδοση της επίθεσης στις ρωσικές υπηρεσίες πληροφοριών (SVR / CozyBear) από κυβερνήσεις των ΗΠΑ και της Ευρώπης.

ΥΠΟΕΝΌΤΗΤΑ 4.1: ΑΙΤΊΕΣ ΚΑΘΥΣΤΕΡΗΜΈΝΟΥ ΕΝΤΟΠΙΣΜΌΥ (ΓΙΑΤΊ Η ΕΠΊΘΕΣΗ ΠΑΡΈΜΕΙΝΕ “ΑΌΡΑΤΗ”)

Ο παρατεταμένος χρόνος παραμονής (dwell time) των επιτιθέμενων χωρίς να γίνουν αντιληπτοί εγκαίρως, οφειλόταν στην άρτια επιχειρησιακή ασφάλεια μιας Προηγμένης Επίμονης Απειλής (APT) και στην εκμετάλλευση των θεμελίων της «ψηφιακής εμπιστοσύνης».

Οι βασικές αιτίες αποτυχίας των αμυντικών μηχανισμών συνοψίζονται στους εξής άξονες:

1. **Ανεπάρκεια των Sandboxes και της Δυναμικής Ανάλυσης:** Αρχικά, ο προγραμματισμένος λήθαργος του κακόβουλου λογισμικού (dormancy) ανέδειξε την τρωτότητα των αυτοματοποιημένων περιβαλλόντων ελέγχου (sandboxes). Επειδή τα συστήματα αυτά αναλύουν τη συμπεριφορά ενός νέου αρχείου μόνο για περιορισμένο χρόνο, η εσκεμμένη καθυστέρηση εκτέλεσης του κώδικα οδήγησε στον εσφαλμένο χαρακτηρισμό του ως ασφαλούς.
2. **Αδυναμία των Signature-based Antivirus:** Τα παραδοσιακά Antivirus βασίζονται στην αναγνώριση γνωστών "υπογραφών" σε αρχεία του σκληρού δίσκου. Καθώς η επίθεση εκτελέστηκε κυρίως απευθείας στη μνήμη RAM (fileless malware) και συνοδεύτηκε από στοχευμένη απενεργοποίηση των ελέγχων του Μητρώου (Registry), τα συστήματα προστασίας τερματικών (Endpoint Protection) αδυνατούσαν να εντοπίσουν την απειλή.
3. **Αποτυχία των Συστημάτων DLP (Data Loss Prevention):** Τα εργαλεία αποτροπής διαρροής δεδομένων είναι σχεδιασμένα να μπλοκάρουν τεράστιους όγκους μεταφοράς ή συγκεκριμένες λέξεις-κλειδιά. Ως αποτέλεσμα, η σταδιακή εξαγωγή πληροφοριών μέσω μικρών, κωδικοποιημένων ερωτημάτων DNS παρέκαμψε πλήρως αυτά τα φίλτρα, καθώς η κακόβουλη ροή παρουσιάστηκε ως φυσιολογική δραστηριότητα δικτύου του πρωτοκόλλου της Orion.
4. **Τυφλή Ψηφιακή Εμπιστοσύνη (Whitelisting):** Το μεγαλύτερο σφάλμα αρχιτεκτονικής ήταν η απόλυτη εμπιστοσύνη στα συστήματα υπογραφής κώδικα (code signing). Ειδικότερα, εφόσον το μολυσμένο λογισμικό έφερε την έγκυρη υπογραφή της SolarWinds, τα συστήματα EDR το τοποθέτησαν αυτόματα σε λευκή λίστα (whitelist), εξαιρώντας το από περαιτέρω αναλύσεις συμπεριφοράς.
5. **Παραπλάνηση των Logs Ταυτοποίησης:** Μέσω της τεχνικής "Golden SAML", οι επιτιθέμενοι πλαστογράφησαν την ίδια την ψηφιακή ταυτότητα των χρηστών. Έτσι, τα συστήματα ελέγχου ταυτότητας κατέγραφαν απολύτως νόμιμες συνδέσεις. Διαπιστώνεται, λοιπόν, ότι η απουσία συστημάτων Ανάλυσης Συμπεριφοράς Χρηστών (UEBA) στέρησε από τους οργανισμούς τη δυνατότητα να αντιληφθούν ότι οι "νόμιμοι" χρήστες εκτελούσαν ασυνήθιστες ενέργειες.

ΥΠΟΕΝΌΤΗΤΑ 4.2: Η ΕΣΦΑΛΜΈΝΗ ΑΠΌΔΟΣΗ ΑΙΤΙΌΤΗΤΑΣ: Ο ΜΎΘΟΣ ΤΟΥ "SOLARWINDS123"

Το 2019 είχε διαρρεύσει ο εξαιρετικά αδύναμος κωδικός "solarwinds123" σε ένα δημόσιο αποθετήριο στο GitHub, επιτρέποντας ελεύθερη πρόσβαση σε έναν FTP διακομιστή της εταιρείας, γεγονός που ανέδειξε σοβαρά κενά στην πολιτική ασφαλείας της εταιρείας. Ωστόσο, έχει αποδειχθεί πως η σύνδεσή του με τη συγκεκριμένη επίθεση είναι τεχνικά αβάσιμη (Cimpranu, 2020).

Ο λόγος κρύβεται στην ίδια την αρχιτεκτονική της παραβίασης. Το κακόβουλο SUNSPOT δεν εγκαταστάθηκε σε κάποιον απλό διακομιστή διανομής αρχείων, όπως ήταν ο εκτεθειμένος FTP. Αντίθετα, οι επιτιθέμενοι χρειάστηκε να διεισδύσουν πολύ πιο βαθιά. Στόχευσαν τον απόλυτα απομονωμένο πυρήνα της παραγωγής, δηλαδή το περιβάλλον όπου "χτίζεται" ο κώδικας (CI/CD pipeline) (CrowdStrike, 2021).

Εάν υποτεθεί πως οι επιτιθέμενοι είχαν αξιοποιήσει τον κωδικό αυτόν απλώς για να αντικαταστήσουν την τελική ενημέρωση του Orion στον διακομιστή FTP, το εγχείρημά τους θα είχε άμεσα αποτραπεί. Ένα εκ των υστέρων αλλοιωμένο αρχείο δεν θα έφερε την έγκυρη ψηφιακή υπογραφή της εταιρείας. Ως εκ τούτου, οι αμυντικοί μηχανισμοί των πελατών θα εντόπιζαν την παραβίαση ακεραιότητας, απορρίπτοντας αυτομάτως την εγκατάσταση. Προκειμένου να πετύχει η επίθεση, η "εμφύτευση" του κακόβουλου κώδικα έπρεπε να προηγηθεί της κρυπτογραφικής υπογραφής. Συνεπώς, ο κωδικός που είχε διαρρεύσει στο ίντερνετ ήταν εντελώς περιττός και δεν παρείχε καμία απολύτως πρόσβαση.

ΥΠΟΕΝΌΤΗΤΑ 4.3: ΣΤΡΑΤΗΓΙΚΆ ΜΈΤΡΑ ΘΩΡΆΚΙΣΗΣ ΚΑΙ ΑΠΟΤΡΟΠΉΣ

Η παραβίαση της SolarWinds ανέδειξε την ανεπάρκεια των παραδοσιακών αμυντικών προσεγγίσεων απέναντι σε επιθέσεις APT (Advanced Persistent Threat), οι οποίες δρούν σιωπηλά για παρατεταμένα χρονικά διαστήματα. Για την αποτροπή παρόμοιων περιστατικών στο μέλλον, παρατίθενται τα παρακάτω τεχνικά και οργανωτικά μέτρα:

A. Αρχιτεκτονική Zero Trust και Διαχείριση Πρόσβασης**• Αρχή των Ελάχιστων Προνομίων (Least Privilege) & PAM:**

Αρχικά, εφαρμογές όπως το Orion δεν πρέπει να εκτελούνται με υπερβολικά δικαιώματα (π.χ. Domain Admin). Απαιτείται η χρήση λύσεων Privileged Access Management (PAM), όπου τα δικαιώματα διαχειριστή αποδίδονται δυναμικά μέσω της μεθόδου Just-in-Time (JIT) για αυστηρά περιορισμένο χρόνο (NIST 2020).

- **Αυστηρή Δικτυακή Τμηματοποίηση (Network Segmentation):** Κρίνεται επίσης απαραίτητη και η αυστηρή δικτυακή τμηματοποίηση (network segmentation) που διαχωρίζει το δίκτυο σε μικρότερες, απομονωμένες ζώνες με αυστηρές πολιτικές ελέγχου (least privilege), περιορίζοντας το “lateral movement” των εισβολέων, δηλαδή την ανεμπόδιστη μεταπήδηση από τους παραβιασμένους διακομιστές Orion, στους κρίσιμους διακομιστές ταυτοποίησης (ADFs).
- **Προστασία Διακομιστών ADFs (Tier Zero):** Για την αποτροπή επιθέσεων κλιμάκωσης προνομίων (όπως το Golden SAML), οι διακομιστές ADFs πρέπει να αντιμετωπίζονται ως κρίσιμη υποδομή “Tier Zero”, με επίπεδο ασφάλειας αντίστοιχο των Domain Controllers. Σε περίπτωση παραβίασης, απαιτείται η ολική αντικατάσταση του πιστοποιητικού υπογραφής SAML. Παράλληλα, επιβάλλεται η χρήση ισχυρότερων μεθόδων ελέγχου ταυτότητας, όπως υλικά κλειδιά (Hardware Keys / FIDO2), τα οποία είναι ανθεκτικά σε επιθέσεις Phishing και Session Hijacking.

Β. Ενισχυμένη Ανίχνευση και Παρακολούθηση (Monitoring)

- **Ανάλυση Συμπεριφοράς (UEBA & DLP):** Επειδή οι επιτιθέμενοι εξαγουν δεδομένα σταδιακά, απαιτούνται συστήματα User and Entity Behavior Analytics (UEBA). Έτσι, μια ελάχιστη διαρροή δεδομένων προς μια μη αναμενόμενη διεύθυνση IP θα επισημανθεί άμεσα ως ανωμαλία, λειτουργώντας συμπληρωματικά των συστημάτων Data Loss Prevention (DLP).
- **Παρακολούθηση Ακεραιότητας Αρχείων (FIM):** Τα συστήματα File Integrity Monitoring είναι απαραίτητα για τον άμεσο εντοπισμό τροποποιήσεων σε κρίσιμα αρχεία. Αυτό συμβαίνει διότι εάν ένα αρχείο πηγαίου κώδικα αλλοιωθεί δευτερόλεπτα πριν τη διαδικασία του build, το σύστημα πρέπει να εκπέμψει άμεσα συναγερμό (alert).

Γ. Ασφαλής Διαδικασία Παραγωγής Λογισμικού (Secure Build Process)

Κρίνεται αναγκαία η ολική αναδόμηση της αυτοματοποιημένης διαδικασίας παραγωγής λογισμικού, για να διασφαλιστεί ότι δεν είναι δυνατή η έγχυση κακόβουλου κώδικα:

- **Παράλληλα και Εφήμερα Περιβάλλοντα:** Το λογισμικό πρέπει πλέον να δημιουργείται ταυτόχρονα σε τρία διαφορετικά και πλήρως απομονωμένα περιβάλλοντα (build servers), τα οποία είναι προσωρινά και διαγράφονται αμέσως μετά τη χρήση τους. (όπως έπραξε και η SolarWinds εκ των υστέρων)

- **Έλεγχος Ακεραιότητας & Ψηφιακή Υπογραφή:** Μόλις ολοκληρωθούν τα τρία παράλληλα builds, το σύστημα συγκρίνει τα τελικά εκτελέσιμα. Η επίσημη ψηφιακή υπογραφή της εταιρείας (code signing) ενσωματώνεται στο λογισμικό μόνο εάν το αποτέλεσμα είναι απόλυτα ταυτόσημο και στα τρία περιβάλλοντα, εξασφαλίζοντας την ακεραιή προέλευση του κώδικα. Παράλληλα, οι οργανισμοί πρέπει να απαιτούν την παροχή Λίστας Υλικών Λογισμικού (SBOM) για πλήρη διαφάνεια.

Δ. Η Οικονομική και Κανονιστική Διάσταση (Governance & Risk)

Σε διοικητικό επίπεδο η περίπτωση της SolarWinds ανέδειξε την ανάγκη αντιμετώπισης των κυβερνοεπιθέσεων ως μείζονα οικονομικά γεγονότα. Αρχικά, επισήμανε τον τεράστιο συστημικό κίνδυνο, καθώς η παραβίαση ενός μόνο προμηθευτή προκάλεσε οικονομικό «ντόμινο» σε χιλιάδες οργανισμούς. Γι' αυτό, απαιτείται πλέον από τις ρυθμιστικές αρχές (όπως η SEC) οι εταιρείες να δηλώνουν το ακριβές κόστος των παραβιάσεων (Quantified Disclosure) προκειμένου να διασφαλίζεται η διαφάνεια προς τους επενδυτές και να αποτρέπεται η συγκάλυψη του πραγματικού ρίσκου. Τέλος, ξεκαθαρίστηκε ότι η Κυβερνοασφάλιση (Cyber Insurance) καλύπτει απλώς τις οικονομικές απώλειες της εταιρείας που δέχτηκε την επίθεση (π.χ. νομικά έξοδα, πρόστιμα, αποζημιώσεις πελατών) και δεν μπορεί σε καμία περίπτωση να υποκαταστήσει την πραγματική τεχνολογική προστασία ενός οργανισμού.

Η ανάλυση της επίθεσης καθιστά σαφές ότι η παραδοσιακή άμυνα δεν επαρκεί πλέον και πως η τυφλή εμπιστοσύνη σε λογισμικό τρίτων αποτελεί τεράστιο ρίσκο. Επομένως, απαιτείται η μετάβαση σε ένα προσαρμοστικό μοντέλο μηδενικής εμπιστοσύνης (Zero Trust), όπου η παραβίαση του δικτύου θεωρείται εκ των προτέρων δεδομένη ("assume breach").

Ωστόσο, η αναθεώρηση αυτή δεν είναι μόνο τεχνικής φύσεως, αλλά πρωτίστως οικονομικής. Η κυβερνοασφάλεια πρέπει να πάψει να αντιμετωπίζεται απλώς ως ένα λειτουργικό έξοδο του τμήματος Πληροφορικής και να αναγνωριστεί ως κρίσιμη στρατηγική επένδυση.

Επομένως, για να προστατεύσουν οι οργανισμοί όχι μόνο τα δεδομένα τους αλλά και την οικονομική τους βιωσιμότητα, οφείλουν να ενσωματώσουν τον συνεχή έλεγχο και τη δυναμική ανάλυση στο εσωτερικό των δικτύων τους, εντοπίζοντας τις απειλές πριν αυτές προκαλέσουν ανεπανόρθωτη ζημιά.

- **Anisa, G. and Widianingsih, F. (2024)** 'SolarWinds Attack: Stages, Implications, and Mitigation Strategies in the Cyber Age', *Electronic Integrated Computer Algorithm Journal*, 2(1), pp. 47-52. Διαθέσιμο στο: <https://journal.yasib.com/index.php/enigma/article/view/31> [Πρόσβαση: 23 Μαρτίου 2026].
- **Buresh, D.L. (2022)** 'The Solar Winds Cyber-Attack, The Federal and Private Sector Response, and the Recommendations and Lessons Learned', *International Journal of Innovation Scientific Research and Review*, 4(10), pp. 3469-3479. Διαθέσιμο στο: https://dlwqtxtslxzle7.cloudfront.net/98625329/SolarWinds_Published_Article_Donald_Buresh-libre.pdf [Πρόσβαση: 23 Μαρτίου 2026].
- **Cybersecurity and Infrastructure Security Agency (CISA) (2020)** AA20-352A: Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations. Διαθέσιμο στο: <https://content.govdelivery.com/accounts/USDHSCISA/bulletins/2b1b32d> [Πρόσβαση: 23 Μαρτίου 2026].
- **Cybersecurity and Infrastructure Security Agency (CISA) (2021c)** MAR-10318845-1.v1 - SUNBURST. Διαθέσιμο στο: <https://www.cisa.gov/news-events/analysis-reports/ar21-039a> [Πρόσβαση: 23 Μαρτίου 2026].
- **Fortinet (no date)** 'SolarWinds Supply Chain Attack', Fortinet CyberGlossary. Διαθέσιμο στο: <https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack> [Πρόσβαση: 23 Μαρτίου 2026].
- **Gurbanova, A. (2025)** Security Vulnerabilities and Strategic Responses: The SolarWinds Supply Chain Attack and Its Implications for Global Cybersecurity. Master's thesis. Charles University. Διαθέσιμο στο: <https://dspace.cuni.cz/bitstream/handle/20.500.11956/207253/120515703.pdf> [Πρόσβαση: 23 Μαρτίου 2026].

- **Kruti, A., Butt, U. and Sulaiman, R.B. (2023)** 'A review of SolarWinds attack on Orion platform using persistent threat agents and techniques for gaining unauthorized access', arXiv preprint. Διαθέσιμο στο: <https://arxiv.org/abs/2308.10294> [Πρόσβαση: 23 Μαρτίου 2026].
- **Kurtz, G. (2021)** Testimony on Cybersecurity and Supply Chain Threats. Senate Select Committee on Intelligence. Διαθέσιμο στο: <https://www.intelligence.senate.gov/wp-content/uploads/2024/08/sites-default-files-documents-os-gkurtz-022321.pdf> [Πρόσβαση: 23 Μαρτίου 2026].
- **Martínez, J. and Durán, J.M. (2021)** 'Software supply chain attacks, a threat to global cybersecurity: SolarWinds' case study', International Journal of Safety and Security Engineering, 11(5), pp. 537-545. Διαθέσιμο στο: https://iijeta.org/sites/default/files/pdf/2021-11/11.05_05.pdf [Πρόσβαση: 23 Μαρτίου 2026].
- **Pritchard, D. (2023)** The SolarWinds Hack: How, Why, and What Could've Prevented it. Unpublished essay. Old Dominion University. Διαθέσιμο στο: <https://sites.wp.odu.edu/darrenpritchard/wp-content/uploads/sites/33517/2023/08/Short-Essay-1-CYSE-300.pdf> [Πρόσβαση: 23 Μαρτίου 2026].
- **Tran, C. (2021)** 'The SolarWinds attack and its lessons', E-International Relations. Διαθέσιμο στο: <https://www.e-ir.info/2021/06/17/the-solarwinds-attack-and-its-lessons/> [Πρόσβαση: 23 Μαρτίου 2026].
- **U.S. Government Accountability Office (GAO) (2022)** Cybersecurity: Federal Response to SolarWinds and Microsoft Exchange Incidents. Διαθέσιμο στο: <https://www.gao.gov/products/gao-22-104746> [Πρόσβαση: 23 Μαρτίου 2026].
- **Vijayan, J. (2020)** 'SolarWinds Campaign Focuses Attention on 'Golden SAML' Attack Vector', Dark Reading. Διαθέσιμο στο: <https://www.darkreading.com/cyberattacks-data-breaches/solarwinds-campaign-focuses-attention-on-golden-saml-attack-vector> [Πρόσβαση: 23 Μαρτίου 2026].
- **Willetts, M. (2021)** 'Lessons of the SolarWinds Hack', Survival, 63(2), pp. 7-26. Διαθέσιμο στο: <https://www.tandfonline.com/doi/epdf/10.1080/00396338.2021.1906001?needAccess=true> [Πρόσβαση: 23 Μαρτίου 2026].

- **Vaughan-Nichols, S.J. (2021)**. SolarWinds security fiasco may have started with simple password blunders. [online] ZDNET. Διαθέσιμο στο: <https://www.zdnet.com/article/solarwinds-security-fiasco-may-have-started-with-simple-password-blunders/> [Πρόσβαση 1 Απρ. 2026].
- **CrowdStrike (2021)** 'SUNSPOT: An Implant in the Build Process', CrowdStrike Blog. Διαθέσιμο στο: <https://www.crowdstrike.com/blog/sunspot-malware-technical-analysis/> [Πρόσβαση: 1 Απριλίου 2026].
- **Cybersecurity and Infrastructure Security Agency (CISA) (2021a)** Alert AA21-008A: Detecting Post-Compromise Threat Activity in Microsoft Cloud Environments. Διαθέσιμο στο: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-008a> [Πρόσβαση: 1 Απριλίου 2026].
- **Cybersecurity and Infrastructure Security Agency (CISA) (2021b)** Defending Against Software Supply Chain Attacks. CISA & NIST. Διαθέσιμο στο: https://www.cisa.gov/sites/default/files/publications/defending_against_software_supply_chain_attacks_508_1.pdf [Πρόσβαση: 1 Απριλίου 2026].
- **Mandiant (2020)** 'Highly Evasive Attacker Leverages SolarWinds Supply Chain to Compromise Multiple Global Victims With SUNBURST Backdoor', Mandiant Threat Research. Διαθέσιμο στο: <https://cloud.google.com/blog/topics/threat-intelligence/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor> [Πρόσβαση: 1 Απριλίου 2026].
- **Microsoft (2021)** 'Deep dive into the Solorigate second-stage activation: From SUNBURST to Teardrop and Raindrop', Microsoft Security Blog. Διαθέσιμο στο: <https://www.microsoft.com/security/blog/2021/01/20/deep-dive-into-the-solorigate-second-stage-activation-from-sunburst-to-teardrop-and-raindrop/> [Πρόσβαση: 1 Απριλίου 2026].

- **Ramakrishna, S. (2025)** 'An investigative update of the Cyberattack', SolarWinds Blog. Διαθέσιμο στο: <https://www.solarwinds.com/blog/an-investigative-update-of-the-cyberattack> [Πρόσβαση: 22 Μαρτίου 2026].
- **Symantec (2021)** 'SolarWinds: How a Rare DGA Helped Attacker Communications Fly Under the Radar', Broadcom Software Blogs. Διαθέσιμο στο: <https://www.security.com/solarwinds/solarwinds-unique-dga-0> [Πρόσβαση: 1 Απριλίου 2026].
- **NIST (2020)** NIST Special Publication 800-207: Zero Trust Architecture. National Institute of Standards and Technology. Διαθέσιμο στο: <https://csrc.nist.gov/publications/detail/sp/800-207/final> [Πρόσβαση: 1 Απριλίου 2026].
- **MITRE ATT&CK (2021)** SUNBURST, Software S0559. Διαθέσιμο στο: <https://attack.mitre.org/software/S0559/> [Πρόσβαση: 2 Απριλίου 2026].
- **SolarWinds Corporation (2020)** Form 8-K: Current Report, U.S. Securities and Exchange Commission, 14 December. Διαθέσιμο στο: <https://www.sec.gov/Archives/edgar/data/1739942/000162828020017451/swi-20201214.htm> [Πρόσβαση: 2 Απριλίου 2026].
- **U.S. Securities and Exchange Commission (SEC) (2023)** 'SEC Charges SolarWinds and Chief Information Security Officer with Fraud, Internal Control Failures', Press Release 2023-227, 30 October. Διαθέσιμο στο: <https://www.sec.gov/newsroom/press-releases/2023-227> [Πρόσβαση: 2 Απριλίου 2026].

ΔΗΛΩΣΗ ΧΡΗΣΗΣ ΓΕΝΑΙ

Κατά την εκπόνηση της παρούσας εργασίας, χρησιμοποιήθηκε το γλωσσικό μοντέλο τεχνητής νοημοσύνης Gemini ως υποστηρικτικό εργαλείο μελέτης και επιμέλειας. Πιο συγκεκριμένα, το εργαλείο αξιοποιήθηκε για:

- **Την κατανόηση τεχνικών εννοιών και τον εντοπισμό πηγών:** Αξιοποίηση του μοντέλου ως εργαλείου υποβοήθησης για την εις βάθος κατανόηση συγκεκριμένων μηχανισμών της επίθεσης (π.χ. διαφοροποίηση Teardrop/Raindrop, λειτουργία Golden SAML) και την ανάκτηση έγκυρων εξωτερικών αναφορών (π.χ. CISA, Microsoft, Mandiant).
- **Την αξιολόγηση και βελτιστοποίηση της δομής:** Εντοπισμός εννοιολογικών επαναλήψεων μεταξύ της τεχνικής ανάλυσης (Μέρος Β) και των προτεινόμενων στρατηγικών (Μέρος Γ), προκειμένου να διασφαλιστεί η διακριτή λειτουργία του κάθε τμήματος.
- **Τη σύντμηση και φιλολογική επιμέλεια:** Βελτίωση της συντακτικής ροής, συμπύκνωση του κειμένου με στόχο την αυστηρή τήρηση του ακαδημαϊκού ορίου λέξεων.

Διευκρινίζεται ότι η πρωτογενής έρευνα, η μελέτη των πηγών, η χαρτογράφηση της επίθεσης στο πλαίσιο MITRE ATT&CK, η κριτική προσέγγιση του οικονομικού κινδύνου και η τελική σύνθεση των επιχειρημάτων, αποτελούν αποκλειστικά πνευματικό έργο των συγγραφέων.